

PDF文档二：查询用户信息 / 权限 / 身份（详细版）

文档编号：IT-SEC-002

版本：V2.0

密级：内部敏感

生效日期：2026-08-14

1. 目的

规范用户信息、权限及身份查询行为，明确查询权限、审批流程、操作规范、日志审计与违规处理要求，防止个人信息与系统权限被滥用或泄露，满足《个人信息保护法》《数据安全法》等法律法规及公司合规要求。

2. 适用范围

适用于公司内部因工作需要查询用户基本信息、账号状态、权限配置、身份认证记录、登录日志等场景。包括但不限于：IT支持、安全审计、合规调查、人事管理、业务协作。

3. 术语定义

- 用户信息**：包括姓名、工号、部门、岗位、联系方式、邮箱、账号、设备信息等与个人身份相关的数据。
- 权限**：用户对系统、数据、功能的访问和操作范围，包括角色、菜单权限、数据权限、特殊授权等。
- 身份查询**：核实用户身份真实性、账号有效性、认证记录、登录行为等。
- 敏感个人信息**：根据法律法规，包括身份证号、生物识别、行踪轨迹、宗教信仰、医疗健康等（本规范所指用户信息一般不包含此类，但需注意关联）。
- 最小必要原则**：仅查询与工作目的直接相关的最小范围数据。

4. 基本原则

- 合法必要**：查询须基于明确、合法的工作需要，遵循最小必要原则。
- 审批授权**：未经批准，任何人不得擅自查询他人信息或权限。

- 3. 保密义务：查询结果仅限用于申请目的，不得向无关人员透露、复制或转发。
- 4. 全程留痕：所有查询行为必须记录日志，可审计、可追溯。
- 5. 职责分离：查询人、审批人、使用人应尽量分离，避免权力集中。

5. 查询权限与角色矩阵（详细）

角色	可查询范围	审批要求	备注
普通员工	仅本人信息及本人权限	自助查询，无需审批	通过自助平台
IT服务台	用户基础信息（姓名、工号、部门、邮箱、账号状态）、常见权限	需工单或用户授权	不得查询登录日志、认证记录
系统管理员	权限配置信息、角色分配	需变更工单或安全审批	不得随意查询个人通讯录等非必要信息
信息安全人员	用户信息、权限、认证日志、登录记录	需安全负责人审批	仅限安全事件调查、审计
审计人员	用户信息、权限、操作日志	需审计委员会或安全负责人审批	按审计计划执行
人力资源/合规	员工基础信息、岗位状态、组织架构	按HR流程审批	不涉及系统权限细节
法务/纪检	用户信息、权限、日志	需法务负责人+安全负责人联合审批	仅限正式调查

6. 查询场景与审批流程（详细）

6.1 用户信息查询

场景A：业务协作查询基础联系方式

- 查询范围：姓名、部门、邮箱、办公电话
- 审批：无需审批，通过公司通讯录或经对方同意

- 禁止查询：家庭住址、个人手机号（除非本人主动提供）

场景B：因系统支持需查询账号状态

- 查询范围：账号是否存在、锁定状态、最近登录时间（模糊）
- 审批：需有用户工单或用户本人授权
- 操作：IT服务台在工单中记录查询原因

场景C：因审计、调查需查询详细用户信息

- 查询范围：全部基础信息、账号信息、关联设备
- 审批：提交《信息查询申请单》，经部门负责人+信息安全负责人审批
- 有效期：审批有效期不超过7个工作日，超期需重新审批

6.2 权限查询

场景A：用户自查本人权限

- 方式：通过自助服务平台查看
- 审批：无需审批

场景B：他人权限查询

- 查询范围：指定系统、指定用户的角色与权限列表
- 审批：说明业务原因，经被查询人主管或发起人主管审批
- 涉及敏感系统（如财务、人力资源、客户数据平台）需信息安全官复核

场景C：批量权限审计查询

- 查询范围：多个用户、多个系统的权限集合
- 审批：审计计划经审计委员会批准，或安全负责人专项批准
- 要求：查询结果仅用于审计目的，不得用于其他用途

6.3 身份核验查询

场景A：核实账号真实性

- 查询范围：账号是否存在、归属人、创建时间、状态

- 审批：IT服务台因工单需要可直接查询基础信息；安全人员查询需安全负责人审批

场景B：登录日志、认证记录查询

- 查询范围：登录时间、IP地址、认证方式、失败记录
- 审批：仅限信息安全、审计、法务等授权岗位，经安全负责人批准
- 特殊要求：涉及个人行踪轨迹的，须遵守个人信息保护法，严格限制使用范围

6.4 应急查询（安全事件）

在发生信息安全事件（如账号被盗、数据泄露、恶意操作）时：

- 可由信息安全负责人口头授权先行查询，24小时内补办书面审批
- 应急查询范围限于事件调查必需
- 事后必须详细记录查询过程与结果，纳入审计

7. 查询操作规范

1. 提交申请：填写查询目的、对象、数据范围、使用期限、结果接收人
2. 审批：按第6节要求完成业务主管/安全负责人审批
3. 执行查询：由被授权人员在指定系统或工具中执行，禁止超范围查询
4. 结果使用：结果仅用于申请目的，不得复制、转发、存储于非授权位置
5. 记录留存：查询工单及审批记录至少保存3年
6. 数据最小化：查询结果展示时，对无关字段进行脱敏处理
7. 禁止行为：
 - 查询本人或亲友的敏感信息
 - 将查询结果用于私人目的
 - 截图或拍照查询结果并通过非安全渠道传输
 - 绕过审批流程使用技术手段直接查询

8. 日志记录与审计

8.1 日志字段要求

系统应自动记录以下查询日志：

- 查询人（工号、姓名、IP、设备）
- 查询时间（精确到秒）
- 被查询对象（工号、账号、系统）
- 查询类型（信息/权限/身份）
- 查询条件与返回结果条数
- 审批工单编号
- 操作类型（查看、导出、打印）

8.2 审计频率

- 信息安全部门每季度抽查查询行为，覆盖 $\geq 10\%$ 的查询工单
- 对以下高风险行为重点监控：
 - 批量查询（单次 ≥ 50 条）
 - 非工作时间查询
 - 查询已离职员工信息
 - 同一查询人高频查询不同用户
 - 查询结果被导出或打印

8.3 审计发现处理

- 异常查询行为立即暂停相关权限，启动调查
- 确认违规的，按第9节处理

9. 违规处理

违规行为	处理措施
未经授权查询他人基础信息	警告、通报批评
未经授权查询权限或身份日志	记过、调离岗位
将查询结果泄露给无关人员	视后果严重程度，最高解除劳动合同
利用查询信息从事非法活动	解除劳动合同，移交司法机关
批量查询并导出敏感信息	视为严重违纪，解除劳动合同并追究法律责任

10. 附件表单

- 《信息查询申请单》
- 《权限查询审批记录表》
- 《应急查询事后补批记录表》